

JIA YI (JENNY) PAN

jp3956@columbia.edu | 202-341-3717 | New York, NY

EDUCATION

Columbia University, School of Engineering and Applied Science

Expected May 2027

B.S. Computer Science. Entered through the 3-2 dual degree program.

Georgetown University, College of Arts and Sciences

May 2025

B.A. Political Economy. Dean's List and Second Honors in 4 of 6 semesters.

Coursework: AI Software Security, Security I, Advanced Programming in C and UNIX, Fundamentals of Computer Systems, Machine Learning, Algorithms, Parallel Functional Programming.

EXPERIENCE

Security Research Intern, Columbia University Software Systems Lab

Summer 2026 to Present

Cyber NYC REU under Prof. Junfeng Yang and Prof. Suman Jana, funded by Google's Cyber NYC Institutional Research Program.

- Work on CAGE, a red-teaming system for AI agents that combines agent behavior, program data flow, deployment topology, sandbox policy, credentials, and cluster authority into a single attack graph, so multi-stage guardrail failures become visible before deployment.
- Reproduced the OpenAI and Hugging Face security incident in a controlled environment, modeling a coding agent, tool harness, OpenShell sandbox, Artifactory-style proxy, Hugging Face-style service, service-account identity, and a Kubernetes control plane. CAGE reconstructed it as a 13 step cross-layer capability chain running from sandbox policy through internal network access, a code-discovered SSRF, arbitrary file access, command execution, stolen credentials, and Kubernetes authority.
- Evaluated CAGE against five open source agent platforms (HolmesGPT, Skyvern, kagent, Flowise, Langflow) spanning Kubernetes troubleshooting, browser automation, agent tooling, MCP integrations, and subprocess execution, validating every finding against application source to separate real vulnerabilities from expected capabilities and false positives.
- Confirmed a version-based Flowise SSRF result in which CAGE detected the sink in the vulnerable release and stopped detecting it after the patch, and documented the control-flow false positives that survived.
- Designed source-to-sink and sanitizer ablations that strip out security barriers and diff the resulting attack graphs, so a null result can be attributed to the application rather than to incomplete static analysis. Documented where the analysis breaks, including interprocedural data-flow reconstruction, SSRF guard modeling, trust boundary separation, sink classification, and TypeScript and Go frontend coverage.
- Earlier in the summer, found a command injection in a live MCP server running under a configured allowlist, and measured how name-bound permission checks fail: renaming restricted data fields raised leak rate from 0.50 to 1.00 while name-based monitors caught none of the leaks and a provenance-based monitor caught all of them.
- Built the reproducible artifacts behind these results: pinned commits, deployment manifests, code property graphs, interactive attack graphs, and logged failure analyses. Stood up the toolchain on macOS ARM, including Joern, language frontends, Cargo-based CAGE runs, large CPG exports, and a missing native Go AST generator.

Financial Engineering Intern, Shanghai Rural Commercial Bank

Summer 2025

Listed commercial bank, SSE 601825, RMB 1.45T in total assets, 128th in The Banker's Top 1000 World Banks 2024.

- Evaluated candidate volatility modeling approaches for a fixed income book holding roughly 80 percent of the desk's investments, testing alternatives against historical market data in Python and MATLAB.
- Pulled fixed income and macro time series from the Wind terminal, built the cleaning and aggregation workflows the team used for recurring analysis, and condensed newly published research from global banks and funds into briefings for the team lead.

PROJECTS

TRACE: Hybrid SQL Injection Detector for Python | Python, AST analysis, call graphs, LLM APIs

Spring 2026

COMS 4995 AI Software Security. Sole author of the tool, the evaluation, and the paper.

- Built a command line static analyzer that parses Python into ASTs, constructs a cross-file call graph, and walks dataflow backward from database calls to untrusted input, handling string concatenation, percent formatting, f-strings, .format(), class attributes, and return values.
- Detected all 11 documented CVEs in the Archery production SQL platform plus 10 further candidate findings, and reached F1 0.57 across a 252 file benchmark against 0.20 for Bandit and 0.48 for a single-pass LLM baseline.
- Cut false positive rate from 0.10 to 0.05 by tracing 11 of 17 false positives to a single query builder library and giving the detector file and class context.

Chinese Foreign Direct Investment in Africa | Econometric analysis of Afrobarometer and World Bank data

Spring 2025

- Modeled determinants of public sentiment toward Chinese investment across 36 African countries using Afrobarometer Round 9 micro-data on 33,823 respondents, recoding 11 binary variables from ordinal items and stratifying by World Bank income classification.
- Automated six nested OLS specifications with robust standard errors and country and region fixed effects. Satisfaction with economic management was the strongest predictor at 4.7 percentage points, and approval of media censorship was negative only among upper-middle-income respondents.

TEACHING

Teaching Assistant, PIVOT Program, McDonough School of Business, Georgetown University

2024 to 2025

- Built and revised STEM curricula in statistics, algebra, logic, and programming for 7 formerly incarcerated students across a 20 week program, tracking weekly progress until all 7 met their benchmarks, and reported to program directors and D.C. Department of Employment Services coordinators across 3 institutions.

TECHNICAL SKILLS

Languages: Python, C, C++, Rust, Java, Go, TypeScript, SQL, Bash, MATLAB, R, Stata, YAML

Security: Static taint analysis, code property graphs, Joern, AST and call graph construction, SSRF and command execution analysis, agent sandboxing, access control, threat modeling, fuzzing, MCP security, OWASP Top 10, CVE analysis, Bandit, Semgrep

Systems and Tools: Linux and POSIX, Kubernetes, sockets, Makefiles, Git, Cargo, NumPy, pandas, scikit-learn, Anthropic and OpenAI APIs, Wind terminal, Excel and VBA. English and Mandarin (native), French.